

Ataques de Replay em Dispositivos IoT

Gustavo Henrique de Sousa Nogueira

Sumário

1	Introdução	2
2	Dispositivos IoT de baixo custo e riscos de segurança	2
3	Como funciona um ataque de replay	3
4	Estudo de caso: ataque de replay na Master Lock Deadbolt D1000	4
5	Medidas de proteção contra ataques de replay	5
6	Considerações finais	5

1 Introdução

A Internet das Coisas (IoT) permite que diferentes dispositivos se conectem à rede para trocar informações, enviar dados e receber comandos. Esse tipo de tecnologia está presente em sensores, câmeras, eletrodomésticos, sistemas de automação, fechaduras inteligentes e vários outros equipamentos. Devido a esse grande número de dispositivos, a segurança dessas comunicações também se torna importante. Uma falha pode permitir que terceiros tenham acesso a informações ou até consigam executar comandos sem autorização. Entre os problemas de segurança existentes em redes IoT está o ataque de replay. Nesse tipo de ataque, uma comunicação legítima entre dois dispositivos é capturada e armazenada por um invasor. Depois, essa mesma comunicação é retransmitida para tentar fazer o sistema repetir uma ação que havia sido autorizada anteriormente. Esse tipo de ataque mostra que não basta apenas proteger ou autenticar uma comunicação. O dispositivo também precisa ser capaz de identificar se uma mensagem recebida é realmente nova ou se está sendo reutilizada por alguém.

2 Dispositivos IoT de baixo custo e riscos de segurança

Hoje, se tornou simples encontrar dispositivos IoT para automação residencial por preços baixos na internet. Muitos desses equipamentos são instalados diretamente na rede Wi-Fi de uma residência ou empresa e passam a trocar informações com aplicativos, servidores e outros dispositivos locais. O problema é que, na maioria das vezes, o usuário escolhe o produto pelo preço e pelas funções oferecidas, sem saber como ele foi desenvolvido do ponto de vista de segurança. Em alguns casos, podem existir senhas padrão, comunicação mal protegida, falta de atualizações, aplicativos inseguros ou mecanismos de autenticação pouco confiáveis. Quando um equipamento assim é conectado à mesma rede utilizada por computadores, celulares e outros dispositivos, ele passa a fazer parte daquele ambiente e pode se tornar mais um ponto de vulnerabilidade. Esse risco fica ainda maior quando o dispositivo controla alguma função física, como uma câmera, um alarme, um portão ou uma fechadura inteligente. Entre os problemas que podem aparecer nesses sistemas está a aceitação de uma comunicação passada como se ela fosse nova, o que abre espaço para ataques de replay, nos quais uma mensagem legítima é capturada e reutilizada posteriormente por um invasor.

Outro ponto importante é o tempo de suporte oferecido pelo fabricante.

Diferente de um computador ou celular, que normalmente recebe atualizações de segurança durante alguns anos, alguns dispositivos IoT podem permanecer funcionando por muito tempo sem receber correções. Em outros casos, o fabricante deixa de oferecer suporte ao produto ou o usuário simplesmente não sabe que existe uma atualização disponível. Isso faz com que uma vulnerabilidade descoberta depois da compra possa continuar presente no equipamento. Como esses dispositivos normalmente permanecem conectados à rede durante todo o tempo, uma falha que inicialmente parece pequena pode acabar servindo como ponto de acesso para outros equipamentos ou permitir que funções do próprio dispositivo sejam controladas de maneira indevida.

3 Como funciona um ataque de replay

Em um ataque de replay, o invasor procura primeiro obter uma comunicação que tenha sido realizada de forma legítima entre dois dispositivos. Essa comunicação pode ocorrer por diferentes tecnologias utilizadas em IoT, como Wi-Fi, Bluetooth, ZigBee ou outros protocolos sem fio. Estando próximo da comunicação ou tendo acesso à rede, o atacante pode utilizar equipamentos ou programas capazes de monitorar o tráfego e registrar as mensagens transmitidas. O objetivo não é necessariamente descobrir a senha do usuário ou entender tudo o que está sendo enviado, mas guardar uma comunicação que o sistema já reconheceu como válida. Em outro momento, essas mensagens podem ser retransmitidas tentando se passar pelo dispositivo ou usuário legítimo. Se o equipamento não possuir um mecanismo capaz de perceber que aquela comunicação já ocorreu anteriormente ou que não pertence à sessão atual, poderá aceitar novamente os comandos recebidos. Por isso, o ataque de replay pode funcionar mesmo quando existe criptografia, já que o invasor pode simplesmente repetir os dados capturados sem precisar descriptografá-los. O risco aumenta em equipamentos que executam ações físicas, como alarmes, portões, sistemas de controle de acesso e fechaduras inteligentes, pois uma comunicação capturada pode ser utilizada para tentar repetir uma ação que anteriormente havia sido autorizada.

O replay também não precisa estar limitado a um comando de abertura de uma fechadura. Dependendo do sistema, o invasor pode tentar reutilizar uma autenticação, um comando enviado a um portão, uma ordem para ativar ou desativar um alarme ou até informações transmitidas por sensores. A lógica continua sendo

a mesma: o atacante aproveita uma comunicação que foi realmente gerada por alguém autorizado e tenta utilizá-la novamente para ser reconhecido como parte legítima do sistema. Isso torna o ataque diferente de uma tentativa comum de descobrir uma senha, pois o invasor procura explorar a confiança que o dispositivo já depositou naquela comunicação.

4 Estudo de caso: ataque de replay na Master Lock Deadbolt D1000

Um caso real de ataque de replay foi identificado na fechadura inteligente Master Lock Deadbolt D1000, analisada por pesquisadores da Universidade da Califórnia em San Diego. A fechadura se comunica com o celular por Bluetooth Low Energy (BLE) e utiliza criptografia para proteger os comandos enviados. Durante a pesquisa, a equipe analisou o aplicativo Android utilizado para controlar a fechadura e estudou o protocolo de comunicação entre o celular e o dispositivo. Também foi utilizado um sistema de captura do tráfego Bluetooth para observar as mensagens trocadas durante uma sessão normal. A partir dessa análise, os pesquisadores perceberam que uma sessão completa de comunicação poderia ser registrada e reproduzida posteriormente. Na prática, um atacante que estivesse próximo da fechadura poderia utilizar um sniffer BLE para registrar a comunicação realizada entre o celular de um usuário autorizado e a fechadura durante uma abertura normal. Depois, essas mensagens poderiam ser armazenadas e retransmitidas na mesma sequência. A falha fazia com que a fechadura não identificasse corretamente que aquela sessão já havia ocorrido antes, permitindo que os comandos fossem aceitos novamente, inclusive o comando de destravamento. Isso significa que o invasor não precisava descobrir a senha do usuário nem quebrar a criptografia utilizada pelo sistema, pois podia simplesmente repetir os dados criptografados que haviam sido capturados anteriormente. Os pesquisadores confirmaram o problema desenvolvendo um aplicativo próprio capaz de se comunicar com a fechadura e reproduzir as sessões registradas, demonstrando que o ataque poderia resultar em desbloqueio sem uma nova autorização válida.

5 Medidas de proteção contra ataques de replay

Para evitar ataques de replay, o sistema precisa ter uma forma de perceber que cada comunicação é nova e não uma cópia de algo que já aconteceu antes. Isso pode ser feito utilizando números de sequência, valores únicos gerados a cada nova conexão ou limites de tempo para a validade dos comandos. Assim, se uma mensagem antiga for retransmitida, o dispositivo consegue identificar que ela já foi utilizada ou que não pertence à sessão atual e simplesmente a rejeita. Outra opção é usar mecanismos de desafio e resposta, nos quais o dispositivo exige uma nova validação a cada tentativa de comunicação, impedindo que uma resposta capturada anteriormente continue funcionando. Também é importante utilizar autenticação e criptografia de forma correta, mas a criptografia sozinha não resolve o problema, já que um invasor pode não entender o conteúdo da mensagem e mesmo assim tentar retransmiti-la.

Na prática, é mais seguro utilizar esses mecanismos de forma combinada. O dispositivo pode, por exemplo, criar uma identificação diferente para cada nova sessão e aceitar apenas mensagens relacionadas àquela comunicação. Também pode limitar o tempo em que determinado comando continua válido e exigir uma nova autenticação quando uma nova conexão é iniciada. Além da proteção direta contra replay, manter o firmware atualizado, utilizar protocolos de comunicação seguros e separar dispositivos IoT mais simples do restante da rede ajudam a reduzir os riscos. A separação da rede não impede diretamente um ataque de replay, mas pode limitar o acesso do invasor a outros equipamentos caso um dispositivo seja comprometido.

6 Considerações finais

Os ataques de replay mostram que um invasor pode aproveitar uma comunicação legítima para tentar se passar por um usuário ou dispositivo autorizado, sem necessariamente conhecer a senha ou entender o conteúdo das mensagens trocadas. Esse tipo de ataque pode afetar diferentes dispositivos IoT, como câmeras, alarmes, portões eletrônicos, sensores, sistemas de automação residencial e equipamentos industriais. Por isso, não basta apenas criptografar a comunicação. O sistema também precisa verificar se aquela mensagem pertence realmente à sessão atual e se ainda pode ser aceita. Com mecanismos adequados de autenticação e validação das comunicações, é possível reduzir bastante esse tipo de vulnerabilidade e tornar

os dispositivos IoT mais seguros.